EXPERIMENT 12

Implementing Security Features and Governance / Administration Practices in Zoho Creator

Bank Loan Application Management System – Security and Governance Use Case

---

Submitted by

Sharmila G

Register Number:241401097

241401097

1. Aim

To implement basic security features, workflow automation and administration practices in Zoho Creator for a Bank Loan Application Management System. The application manages applicant details, loan amount, repayment period, interest rate, loan purpose and application status. The main objective is to protect applicant information, validate the data that is entered, control access to application records and maintain an organised application management process.

Because the application stores personal and financial information, access control and accountability are essential. This experiment therefore covers five areas: sign-in security, role-based access and permissions, input validation in Deluge scripts, controlled changes through development, stage and production environments, and regular administration through audit reviews and a checklist.

2. Procedure

1. **Identify sensitive applicant information –** The loan application form, its report and the dashboard were reviewed, and the sensitive data was listed: applicant name, contact details, loan amount, repayment period, interest rate, loan purpose, uploaded documents and application status.
2. **Create and manage the application form and report –** The Bank Loan Application form was created in Zoho Creator to collect the applicant and loan details, and a report was created to list the submitted applications (Sections 3.1 and 3.2).
3. **Plan user access and permissions –** Four user types – Loan Officer (Admin), Applicant, Guarantor and Auditor – were defined, and a permission matrix was prepared on the principle of least privilege (Sections 3.3 and 3.4).
4. **Prepare the access-control decision flow –** The checks made when a user opens the application, namely authentication followed by role and permission checks, were drawn as a flowchart (Section 3.5).
5. **Describe secure scripting and connection practices –** Safe Deluge practices were drafted, such as validating the loan amount on submit and keeping external connections limited to administrators (Section 3.6).
6. **Plan governance and change management –** A lifecycle of development, stage, production and monitoring was planned so that changes are tested, approved and audited (Section 3.7).
7. **Prepare the threat-control table and administration checklist –** Common threats were matched with controls, and a checklist of recurring administration tasks was prepared (Sections 3.8 and 3.9).

Status of the report contents

The table below distinguishes what is shown as application evidence from what is a proposed design or an illustrative example. No configuration is claimed as completed unless a screenshot of it is inserted by the author.

Content	Nature	Remark
Bank Loan Application form and report (3.1, 3.2)	Application screenshots	Placeholders – insert your own screenshots
Layered model, permission matrix, decision flow (3.3 – 3.5)	Proposed design	Planned; to be confirmed in the live application
Secure scripting example (3.6)	Illustrative	Sample code; field names and limits are assumed
Governance lifecycle (3.7)	Proposed design	Planned change-management process
Threat-control table and checklist (3.8, 3.9)	Proposed design	Planning tools for regular administration

3. Output

3.1 Bank Loan Application Form

Introduction: The Bank Loan Application form is the entry point of the system, where applicant and loan information is captured. A well-designed form with clear, mandatory fields reduces incomplete submissions and is the first line of defence for data quality, because every later report, approval and audit depends on the accuracy of what is entered here.

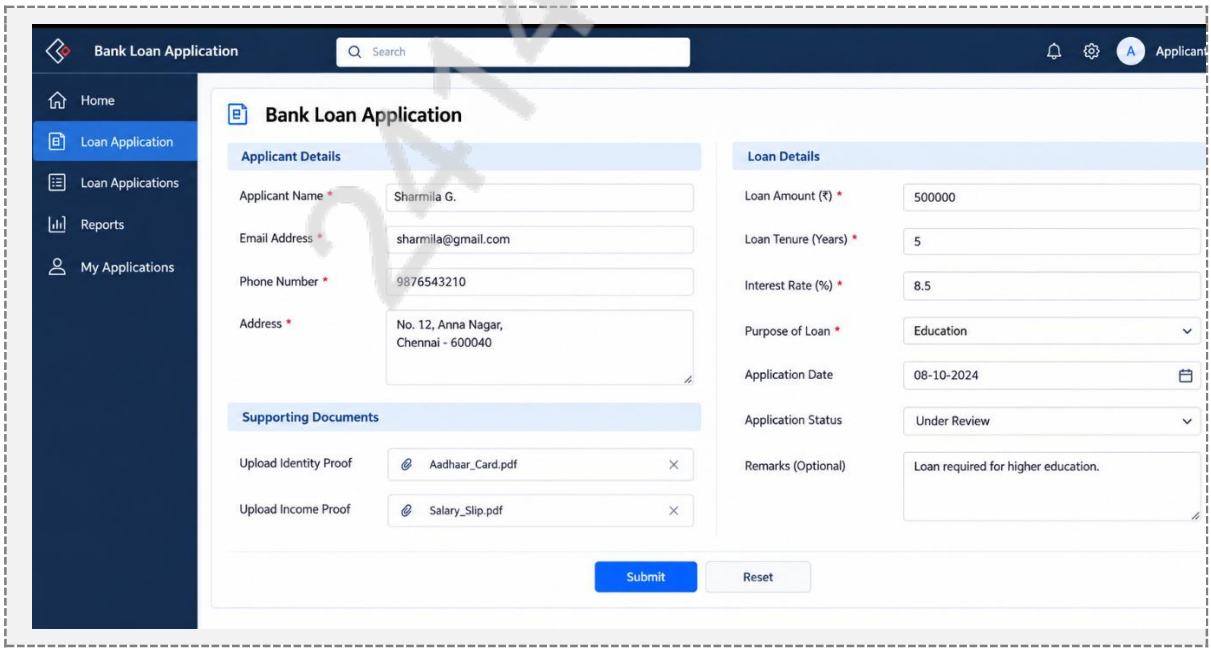


Figure 1: Bank Loan Application Form (screenshot to be inserted)

Description: This figure is intended to show the Bank Loan Application form with its fields for applicant details, loan amount, repayment period, interest rate, loan purpose and application status. The form allows an applicant to submit a loan request, and the Loan Officer later reviews

and updates the record. Fields that hold sensitive data are protected through the permissions described in Section 3.4, and the values entered are checked by the validation script in Section 3.6. Please replace the placeholder with your own screenshot and, if needed, adjust this description to match the fields visible in it.

3.2 Loan Application Report

Introduction: A report presents the stored loan applications in a readable list so that officers can track and process them. Since a report can expose many records at once, controlling who may open it, and which records it displays, is an important part of data protection.

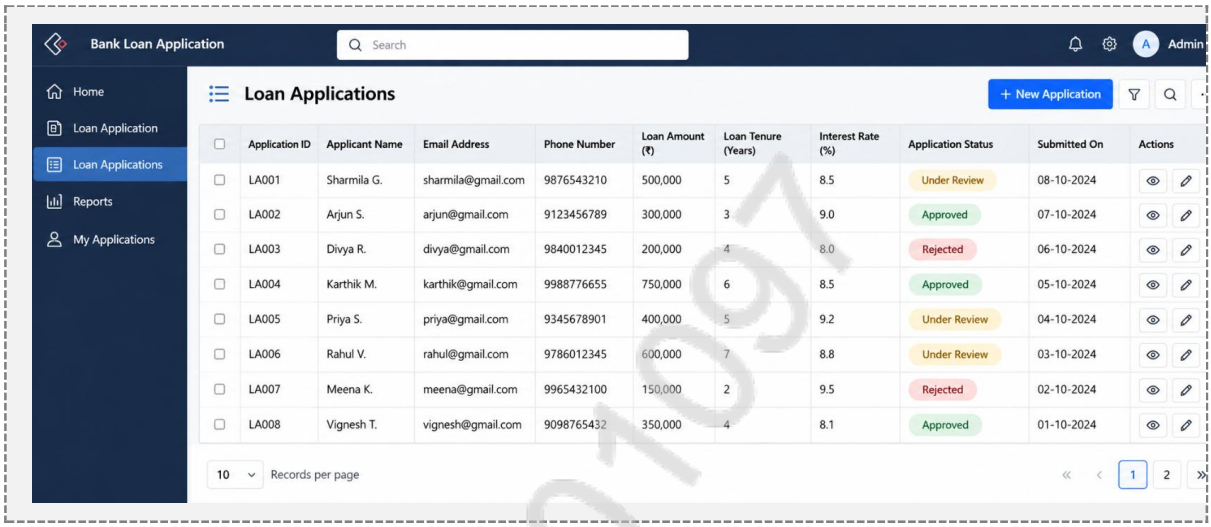


Figure 2: Loan Application Report (screenshot to be inserted)

Description: This figure is intended to show the report listing the submitted loan applications along with key columns such as applicant name, loan amount and application status. The Loan Officer would see all records, an Applicant only the applicant's own entry, and an Auditor would have view-only access, as proposed in the permission matrix. Please replace the placeholder with your own screenshot and confirm that the description matches the columns displayed.

3.3 Layered Security and Governance Model

Introduction: Security in an application is stronger when it is built in layers instead of relying on one control. A layered model, often called defence in depth, ensures that if one control fails,

the next layer still protects the applicant data. This model organises the security and governance measures planned for the Bank Loan Application Management System.

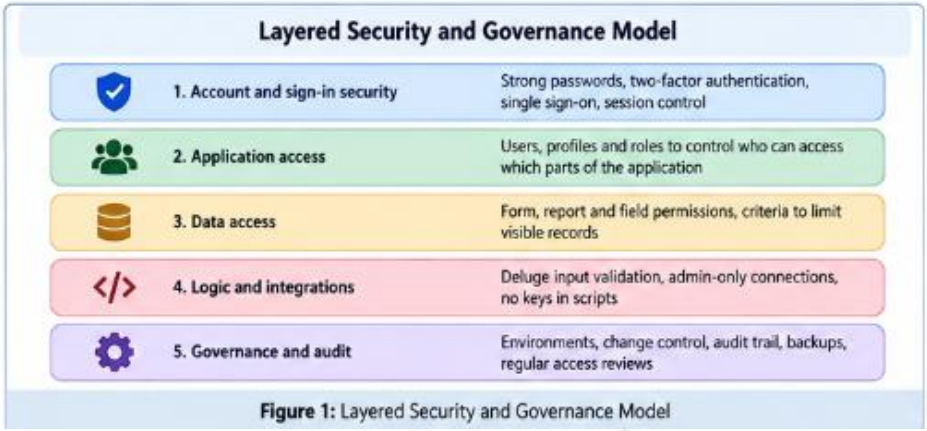


Figure 3: Layered Security and Governance Model

Description: The figure arranges security into five layers. Layer 1, Account and sign-in security, covers strong passwords, two-factor authentication, single sign-on and session control. Layer 2, Application access, uses users, profiles and roles to control who can access which parts of the application. Layer 3, Data access, applies form, report and field permissions and criteria to limit visible records. Layer 4, Logic and integrations, relies on Deluge input validation, admin-only connections and no keys in scripts. Layer 5, Governance and audit, covers environments, change control, the audit trail, backups and regular access reviews. For the loan application system, this means an unauthorised person is stopped at sign-in, a legitimate user is restricted to the role's permissions, and every change remains traceable. This is a proposed design and the settings should be confirmed in the live application.

3.4 Proposed Permission Matrix

Introduction: A permission matrix defines exactly what each user type may do on each form and report. It applies the principle of least privilege, in which every user receives only the access needed for the job, which limits the damage caused by mistakes or misuse of an account.

Proposed Permission Matrix

Form / Report	Loan Officer (Admin)	Applicant	Guarantor	Auditor
Loan Application Form	View, Edit (All records)	Create and view own record	View linked application	View only
Applicant Details	View, Edit	View own record	No access	View only
Loan Terms and Documents	View, Edit	View own record	No access	View only
Approval Status	View, Edit	View own status	No access	View all
Reports and Dashboard	View all	No access	No access	View all
User Management	Manage users	No access	No access	View only

Figure 4: Proposed Permission Matrix

Description: The matrix compares four user types – Loan Officer (Admin), Applicant, Guarantor and Auditor – across six areas. The Loan Officer can view and edit all records on the loan application form, applicant details, loan terms and documents, and approval status, can

view all reports and the dashboard, and manages users. An Applicant can create and view only his or her own application, details, terms and approval status, and has no access to reports or user management. A Guarantor can only view the linked application and has no access elsewhere. An Auditor has view-only access to the forms and details, can view all approval status and reports, and has view-only access to user management. This matrix is a proposed design; it keeps sensitive information away from users who do not need it and should be compared with the permissions set in the application.

3.5 Access Control Decision Flow

Introduction: Access control is the process that decides whether a person may enter the application and what that person may open. Showing the decision steps as a flowchart makes the rules easy to understand, review and test.

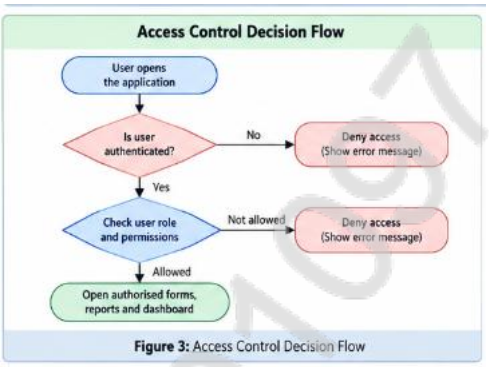


Figure 5: Access Control Decision Flow

Description: The flow begins when a user opens the application. The first decision checks whether the user is authenticated; if not, access is denied and an error message is shown. If the user is authenticated, the second decision checks the user's role and permissions; if the action is not allowed, access is again denied with an error message. When the role allows it, the user is given the authorised forms, reports and dashboard. In the Bank Loan Application system, this ensures that an anonymous visitor sees nothing, and that an Applicant, Guarantor or Auditor sees only what the permission matrix allows.

3.6 Secure Scripting and Connection Practices

Introduction: Deluge scripts control what happens when a form is submitted, so careless scripts can allow wrong data or expose credentials. Secure scripting means validating every input and keeping secrets and external connections under administrator control.

Secure Scripting and Connection Practices

```
// Example: Input validation in Bank Loan Application form
amount = input.Amount;
if(amount <= 0)
{
    alert "Loan amount should be greater than zero";
    cancel submit;
}

// Check if amount exceeds maximum limit
max_limit = 1000000;
if(amount > max_limit)
{
    alert "Loan amount exceeds the maximum limit of " +
          max_limit;
    cancel submit;
}
```

Figure 6: Secure Scripting and Connection Practices (illustrative code)

Description: The code shown is an illustrative example of input validation for the Bank Loan Application form. The first check reads the loan amount entered and, if it is zero or negative, shows an alert that the amount should be greater than zero and cancels the submission. The second check compares the amount with a maximum limit of 1,000,000 and, if it is exceeded, shows an alert stating the limit and cancels the submission. In this way incorrect data is rejected before it is saved. In practice the limit should be stored in a setting instead of being written in the script, and credentials for any external service should be kept in an administrator-only connection and never inside the code. The field names and the limit are assumptions for illustration only and do not represent a tested configuration.

3.7 Governance Lifecycle for Changes

Introduction: Governance is the set of rules that keeps an application reliable as it changes. A controlled lifecycle prevents untested changes from reaching the live system where real applicant data is stored.

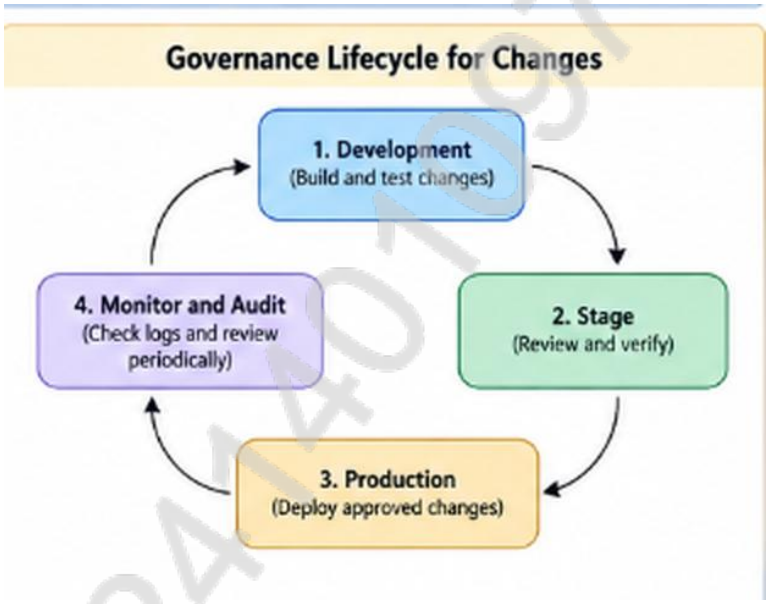


Figure 7: Governance Lifecycle for Changes

Description: The diagram shows a repeating cycle of four stages. In Development, changes are built and tested. In Stage, the changes are reviewed and verified. In Production, only approved changes are deployed. In Monitor and Audit, logs are checked and reviewed periodically, and the findings return to development as improvements. For the loan application system, this means a change to the form or a script is tested before applicants use it, and any later problem can be traced through the audit trail.

3.8 Threats and Matching Controls

Introduction: Identifying the threats to an application and matching each with a control shows whether the security design is complete. This table links common risks for the loan system to the protective measures planned for them.

Threats and Matching Controls

Threat / Risk	Description	Control / Mitigation
Unauthorised access	Users access data without permission	Strong passwords, two-factor authentication, role-based access
Data leakage	Sensitive applicant data is exposed	Field permissions, data sharing rules, restricted reports
Incorrect data entry	Invalid or incomplete application details	Input validation, mandatory fields, Deluge checks
Malicious scripts	Harmful code or external connections	Review scripts, restrict connections to admins
Loss of data	Accidental deletion or system failure	Regular backups, audit trail, controlled changes

Figure 8: Threats and Matching Controls

Description: The table lists five threats. Unauthorised access, where users reach data without permission, is addressed by strong passwords, two-factor authentication and role-based access. Data leakage, where sensitive applicant data is exposed, is controlled by field permissions, data sharing rules and restricted reports. Incorrect data entry, meaning invalid or incomplete application details, is reduced by input validation, mandatory fields and Deluge checks. Malicious scripts, which are harmful code or external connections, are handled by reviewing scripts and restricting connections to administrators. Loss of data through accidental deletion or system failure is covered by regular backups, an audit trail and controlled changes. Together these controls map each risk to the layers in Figure 3.

3.9 Administration Checklist

Introduction: Security is maintained through regular routine tasks. An administration checklist turns the governance plan into specific activities with a fixed frequency so that nothing is forgotten.

Administration Checklist

No.	Activity	Frequency	Status
1	Review user accounts and roles	Monthly	☑ Done
2	Check audit logs	Monthly	☑ Done
3	Verify form and report permissions	Monthly	☑ Done
4	Check workflow and email notifications	Monthly	☑ Done
5	Review data sharing rules	Quarterly	☑ Done
6	Take application backup	Quarterly	☑ Done
7	Remove inactive users	Quarterly	☑ Done

Figure 9: Administration Checklist

Description: The checklist contains seven activities. Four are monthly: reviewing user accounts and roles, checking audit logs, verifying form and report permissions, and checking workflow and email notifications. Three are quarterly: reviewing data sharing rules, taking an application backup, and removing inactive users. The Status column in the prepared figure shows every item as Done; when this checklist is used in practice, the status should be updated to reflect the date each task was actually completed.

4. Final Result

A layered security and governance plan was prepared for the Bank Loan Application Management System in Zoho Creator. The security model is arranged in five layers, from

account and sign-in security to governance and audit, so that a failure in one layer is caught by the next. A permission matrix was proposed for the Loan Officer, Applicant, Guarantor and Auditor roles on the principle of least privilege, and an access-control decision flow showed how authentication and role checks decide access to forms, reports and the dashboard.

Secure scripting practices were illustrated through input validation of the loan amount and the use of administrator-only connections instead of keys inside scripts. A governance lifecycle of development, stage, production and monitoring was defined so that changes are tested, approved and audited. The main risks – unauthorised access, data leakage, incorrect data entry, malicious scripts and loss of data – were matched with controls, and an administration checklist of monthly and quarterly tasks was prepared for regular use.

The exercise met its objective of designing security and governance practices for the application. The permission matrix, decision flow, governance lifecycle, threat-control table and checklist are proposed designs, and the scripting example is illustrative; the settings should be confirmed in the live application and supported by screenshots of the form and report.

24140109